

Low-level logic flaw on an E-commerce website

Ref: CVE-2024-50944

Executive Summary

This report outlined the findings of a security assessment conducted on the e-commerce application. A critical **low-level logic flaw** was identified in the application's purchase workflow, allowing an attacker to manipulate item quantities and exploit integer overflow to purchase high-value items at a negative or unintended price. This flaw poses a significant financial risk to the organization due to potential abuse for fraudulent purchases.

Introduction

The purpose of this security assessment was to identify flaws in the purchasing logic of the target application and assess their impact on transactional integrity. The focus was on testing how the application handles item quantity, price calculation, and store credit during purchases.

Methodology

1. Utilized Burp Suite to intercept and manipulate HTTP requests in the purchase workflow.
2. Analyzed the behavior of item quantity limits and price calculation.
3. Conducted fuzzing attacks using Burp Intruder to test for integer overflow.
4. Observed cart behavior and total price manipulations.
5. Validated the ability to complete an unintended transaction.

Vulnerability Findings

- **Type:** Low-level Logic Flaw (Integer Overflow)
- **Location:** `POST /cart` – quantity parameter
- **Severity:** High

Description

The application restricted item quantities to two digits (e.g., 99) per request. However, this limitation can be bypassed by submitting repeated requests to incrementally add items to the cart. When the total price exceeds the maximum 32-bit signed integer limit (2,147,483,647 cents), it overflows into a negative value due to improper handling of large integers.

An attacker can then continue to add low-cost items to bring the total back under their store credit (e.g., \$100), and successfully place an order that should otherwise cost thousands of dollars.

Proof of Concept (PoC)

1. Logged in using test credentials:
 - Username: `user`
 - Password: `password`
2. Attempted to add 99 jackets repeatedly using Burp Intruder with `quantity=99`.
3. Monitored cart total and observed price flipping to a negative value.
4. Cleared the cart, and then:
 - Sent 323 requests to add 99 jackets.
 - Added 47 jackets manually via Repeater (total = -\$1221.96).
 - Added another item to bring total to < \$100.
5. Successfully placed the order.

Impact Assessment

Exploitation of this logic flaw enabled unauthorized purchase of high-value items without proper payment. Potential consequences include:

- Revenue loss
- Inventory fraud
- Reputational damage
- Regulatory risks related to transaction manipulation

Recommendations

1. Enforce server-side validation for quantity and total pricing logic.
2. Implement bounds checking to detect and reject overflow values.
3. Limit maximum allowed quantity per item or cart session.
4. Store and calculate prices using safe data types that prevent integer overflow.
5. Conduct regular security and logic flow reviews in financial transaction systems.

Conclusion

The discovery of a critical logic flaw highlighted the importance of validating both user input and computational logic at the back-end. Proper handling of integer values and transaction limits is essential to prevent abuse. Remediation of this vulnerability and implementation of recommended controls will greatly improve the application's security and integrity.